

REPORT DI THREAT INTELLIGENCE & ANALISI IOC

Analisi di una cattura di rete tramite Wireshark

Nome e Cognome: Leonardo Onori

Data: 7/8/2026

File analizzato: Cattura_U3_W1_L5.pcapng

1. SOMMARIO ESECUTIVO

L'analisi della cattura di rete fornita ha identificato un singolo evento di sicurezza rilevante: una scansione sistematica delle porte TCP (1–1024) condotta dall'host 192.168.200.100 nei confronti dell'host 192.168.200.150, con l'ausilio, con elevata probabilità, dello strumento Nmap in modalità TCP Connect scan. La scansione ha rivelato 12 porte aperte sul target, il cui fingerprint corrisponde esattamente ai servizi esposti di default dalla macchina didattica vulnerabile Metasploitable2. Non sono stati rilevati, all'interno di questa specifica cattura, scambi di dati applicativi successivi alla scansione: l'attività osservata si colloca quindi nella fase di ricognizione (reconnaissance) di un potenziale attacco, non nella fase di sfruttamento.

2. INTRODUZIONE E OBIETTIVI

Nell'ambito dell'esercitazione sulla Threat Intelligence e sugli Indicatori di Compromissione (IOC), è stata analizzata una cattura di traffico di rete al fine di:

- identificare ed analizzare eventuali IOC presenti;
- formulare ipotesi sul potenziale vettore di attacco utilizzato, sulla base degli IOC riscontrati;
- proporre azioni di mitigazione per ridurre l'impatto dell'attacco osservato ed eventuali attacchi futuri di natura analoga.

3. METODOLOGIA

L'analisi è stata condotta tramite ispezione della cattura di rete in formato pcapng, esaminando la gerarchia dei protocolli, le conversazioni tra host, i flag TCP di ciascun segmento e l'eventuale presenza di payload applicativo (DNS, HTTP, FTP, Telnet). I risultati sono stati incrociati con le informazioni di livello 2 (indirizzi MAC, TTL) per caratterizzare la natura degli host coinvolti.

Wireshark - Protocol Hierarchy Statistics - Cattura_U3_W1_L5.pcapng

Protocol	Percent Packets	Packets	Percent Bytes	Bytes	Bits/s	End Packets	End Bytes
Frame	100.0	2083	100.0	139872	30 k	0	0
Ethernet	100.0	2083	25.2	35276	7,652	0	0
Internet Protocol Version 4	99.8	2079	29.7	41580	9,019	0	0
User Datagram Protocol	0.0	1	0.0	8	1	0	0
NetBIOS Datagram Service	0.0	1	0.1	82	17	0	0
SMB (Server Message Block Protocol)	0.0	1	0.1	162	35	0	0
SMB MailSlot Protocol	0.0	1	0.0	25	5	0	0
Microsoft Windows Browser Protocol	0.0	1	0.1	76	16	1	76
Transmission Control Protocol	99.8	2078	44.8	62652	13 k	2078	62652
Address Resolution Protocol	0.2	4	0.1	112	24	4	112

[FIGURA 1: Wireshark – Protocol Hierarchy]

4. PANORAMICA DELLA CATTURA

- Periodo della cattura: dal 2022-08-09 09:58:59.893818 UTC al 2022-08-09 09:59:36.772714 UTC (durata: 36,88 secondi)
- Pacchetti totali: 2083
- Host coinvolti: esclusivamente due, entrambi con indirizzo MAC riconducibile al vendor Oracle VirtualBox (prefisso 08:00:27), a indicare un ambiente di laboratorio virtualizzato
 - Host A: 192.168.200.100 — MAC 08:00:27:39:7d:fe
 - Host B: 192.168.200.150 — MAC 08:00:27:fd:87:1e
- TTL osservato su entrambi gli host: 64 (valore tipico di stack di rete Linux)

Tabella 1 — Distribuzione dei protocolli:

Protocollo	Pacchetti
TCP	2078
ARP	4
UDP	1

Il traffico UDP (1 pacchetto, servizio NetBIOS Datagram broadcast verso 192.168.200.255) e i 4 pacchetti ARP rappresentano normale rumore di rete locale e non sono correlati all'evento di sicurezza identificato.

5. IDENTIFICAZIONE E ANALISI DEGLI IOC

5.1 IOC principale: scansione sistematica delle porte TCP

L'host 192.168.200.100 ha inviato 1026 segmenti TCP con flag SYN verso 192.168.200.150, coprendo in modo sequenziale e completo l'intero intervallo di porte 1–1024 (1024 porte distinte; le porte 80 e 443 hanno ricevuto ciascuna un secondo SYN, a costituire i restanti 2 segmenti). La copertura totale e sequenziale dell'intervallo, priva di omissioni, è incompatibile con un'interazione umana manuale ed è invece coerente con l'uso di uno strumento di scansione automatizzato.

No.	Time	Source	Destination	Protocol	Length	Info
2	23.764214995	192.168.200.100	192.168.200.150	TCP	74	53060 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81052242...
3	23.764287789	192.168.200.100	192.168.200.150	TCP	74	33876 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81052242...
12	36.774143445	192.168.200.100	192.168.200.150	TCP	74	41304 → 23 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
13	36.774218116	192.168.200.100	192.168.200.150	TCP	74	56120 → 111 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
14	36.774257841	192.168.200.100	192.168.200.150	TCP	74	33878 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
15	36.774366395	192.168.200.100	192.168.200.150	TCP	74	58636 → 554 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
16	36.774485627	192.168.200.100	192.168.200.150	TCP	74	52358 → 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
17	36.774535534	192.168.200.100	192.168.200.150	TCP	74	46138 → 993 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
18	36.774614776	192.168.200.100	192.168.200.150	TCP	74	41182 → 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
29	36.775337809	192.168.200.100	192.168.200.150	TCP	74	59174 → 113 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
30	36.775386694	192.168.200.100	192.168.200.150	TCP	74	55056 → 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
31	36.775524204	192.168.200.100	192.168.200.150	TCP	74	53062 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
42	36.776179338	192.168.200.100	192.168.200.150	TCP	74	50684 → 199 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
43	36.776233880	192.168.200.100	192.168.200.150	TCP	74	54220 → 995 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
44	36.776330610	192.168.200.100	192.168.200.150	TCP	74	34648 → 587 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
45	36.776385694	192.168.200.100	192.168.200.150	TCP	74	33042 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
46	36.776402500	192.168.200.100	192.168.200.150	TCP	74	49814 → 256 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
49	36.776478291	192.168.200.100	192.168.200.150	TCP	74	46990 → 139 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
50	36.776496366	192.168.200.100	192.168.200.150	TCP	74	33206 → 143 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
51	36.776512221	192.168.200.100	192.168.200.150	TCP	74	60632 → 25 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
52	36.776568606	192.168.200.100	192.168.200.150	TCP	74	49654 → 110 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
53	36.776671271	192.168.200.100	192.168.200.150	TCP	74	37282 → 53 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...
54	36.776729715	192.168.200.100	192.168.200.150	TCP	74	54898 → 500 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=81053543...

Frame 31: Packet, 74 bytes on wire (592 bits), 74 bytes captured (592 bits) on 0	0000	08 00 27 fd 87 1e 08 00 27 39 7d fe 08 00 45 00	...E
Ethernet II, Src: PCSSystemtec_39:7d:fe (08:00:27:39:7d:fe), Dst: PCSSystemtec_39:7d:fe (08:00:27:39:7d:fe)	0010	00 3c 7a 00 40 00 00 06 ae 6f c0 a8 c8 64 c0 a8	<2 0 0 o d
Destination: PCSSystemtec_fd:87:1e (08:00:27:fd:87:1e)	0020	c8 96 cf 46 00 50 a3 d5 1a bf 00 00 00 a0 02	F P
.....0..... = IG bit: Globally unique address (factory)	0030	fa f0 12 7b 00 00 02 04 05 b4 04 02 08 0a 30 4f	{ 00
.....0..... = IG bit: Individual address (unicast)	0040	ca ef 00 00 00 00 01 03 03 07	
Source: PCSSystemtec_39:7d:fe (08:00:27:39:7d:fe)			
.....0..... = IG bit: Globally unique address (factory)			
.....0..... = IG bit: Individual address (unicast)			
Type: IPv4 (0x0800)			
[Stream index: 1]			
Internet Protocol Version 4, Src: 192.168.200.100, Dst: 192.168.200.150			
Transmission Control Protocol, Src Port: 53062, Dst Port: 80, Seq: 0, Len: 0			

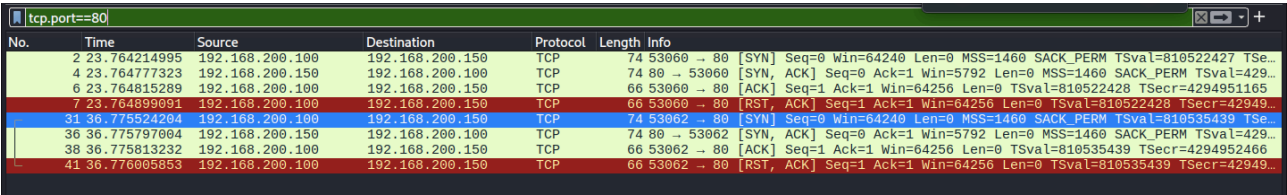
[FIGURA 2: Wireshark – Filtro sui pacchetti SYN in uscita da 192.168.200.100]

Per ciascuna porta di destinazione, la risposta dell'host target segue uno dei due schemi seguenti:

Tabella 2 — Esiti della scansione:

Esito	Sequenza di flag TCP osservata	N. porte
Porta chiusa	SYN → ACK+RST	1012
Porta aperta	SYN → SYN+ACK → ACK → ACK+RST	12

Per le porte aperte si osserva il completamento dell'handshake TCP a tre vie (SYN, SYN-ACK, ACK), seguito immediatamente dalla chiusura della connessione tramite ACK+RST, senza alcuno scambio di dati applicativi. Questo comportamento è la firma caratteristica di una scansione TCP Connect (ad es. tramite Nmap con opzione -sT), tecnica che, a differenza della scansione SYN "half-open" (-sS), richiede il completamento dell'handshake in quanto non necessita di privilegi elevati per la costruzione di pacchetti raw.



[FIGURA 3: Wireshark – Sequenza di handshake su una porta aperta (es. 80)]

5.2 Porte aperte identificate e fingerprint del target

Tabella 3 — Porte aperte rilevate su 192.168.200.150:

Porta	Servizio
21	FTP
22	SSH
23	Telnet
25	SMTP
53	DNS
80	HTTP
111	rpcbind
139	NetBIOS-SSN
445	SMB
512	rexec
513	rlogin
514	rsh/shell

Questa combinazione di servizi, in particolare la compresenza dei servizi Unix "r" (rexec, rlogin, rsh su porte 512–514) e l'assenza di qualsiasi servizio tipico di Windows, unita al valore di TTL pari a 64, identifica con elevata confidenza il sistema target come una macchina Metasploitable2, ambiente didattico intenzionalmente vulnerabile che espone questo esatto insieme di servizi con la configurazione di default.

Ethernet - 2	IPv4 - 2	IPv6	TCP - 1026	UDP - 1							
Address A	Port A	Address B	Port B	Packets	Bytes	Stream ID	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel
192.168.200.100	32792	192.168.200.150	218	2	134 bytes	526	1	74 bytes	1	60 bytes	36.82988
192.168.200.100	32794	192.168.200.150	641	2	134 bytes	931	1	74 bytes	1	60 bytes	36.8702
192.168.200.100	32820	192.168.200.150	49	2	134 bytes	518	1	74 bytes	1	60 bytes	36.8288
192.168.200.100	32852	192.168.200.150	688	2	134 bytes	948	1	74 bytes	1	60 bytes	36.8715
192.168.200.100	32896	192.168.200.150	890	2	134 bytes	637	1	74 bytes	1	60 bytes	36.8387
192.168.200.100	32912	192.168.200.150	382	2	134 bytes	287	1	74 bytes	1	60 bytes	36.8062
192.168.200.100	32922	192.168.200.150	41	2	134 bytes	999	1	74 bytes	1	60 bytes	36.8759
192.168.200.100	32950	192.168.200.150	570	2	134 bytes	74	1	74 bytes	1	60 bytes	36.7822
192.168.200.100	32976	192.168.200.150	690	2	134 bytes	734	1	74 bytes	1	60 bytes	36.8485
192.168.200.100	32996	192.168.200.150	1021	2	134 bytes	425	1	74 bytes	1	60 bytes	36.8199
192.168.200.100	33042	192.168.200.150	445	4	280 bytes	15	3	206 bytes	1	74 bytes	36.7763
192.168.200.100	33050	192.168.200.150	448	2	134 bytes	809	1	74 bytes	1	60 bytes	36.8555
192.168.200.100	33050	192.168.200.150	373	2	134 bytes	826	1	74 bytes	1	60 bytes	36.8572
192.168.200.100	33056	192.168.200.150	521	2	134 bytes	157	1	74 bytes	1	60 bytes	36.7926
192.168.200.100	33058	192.168.200.150	411	2	134 bytes	270	1	74 bytes	1	60 bytes	36.8047
192.168.200.100	33058	192.168.200.150	299	2	134 bytes	511	1	74 bytes	1	60 bytes	36.8283
192.168.200.100	33102	192.168.200.150	51	2	134 bytes	79	1	74 bytes	1	60 bytes	36.7825
192.168.200.100	33114	192.168.200.150	348	2	134 bytes	262	1	74 bytes	1	60 bytes	36.8038
192.168.200.100	33206	192.168.200.150	143	2	134 bytes	18	1	74 bytes	1	60 bytes	36.7764
192.168.200.100	33250	192.168.200.150	355	2	134 bytes	299	1	74 bytes	1	60 bytes	36.8075
192.168.200.100	33280	192.168.200.150	982	2	134 bytes	234	1	74 bytes	1	60 bytes	36.8014
192.168.200.100	33332	192.168.200.150	238	2	134 bytes	366	1	74 bytes	1	60 bytes	36.8135
192.168.200.100	33384	192.168.200.150	1020	2	134 bytes	640	1	74 bytes	1	60 bytes	36.8394
192.168.200.100	33430	192.168.200.150	517	2	134 bytes	193	1	74 bytes	1	60 bytes	36.7963
192.168.200.100	33452	192.168.200.150	77	2	134 bytes	744	1	74 bytes	1	60 bytes	36.8494
192.168.200.100	33460	192.168.200.150	112	2	134 bytes	673	1	74 bytes	1	60 bytes	36.8427
192.168.200.100	33566	192.168.200.150	63	2	134 bytes	305	1	74 bytes	1	60 bytes	36.8084
192.168.200.100	33618	192.168.200.150	91	2	134 bytes	960	1	74 bytes	1	60 bytes	36.8726

[FIGURA 4: Wireshark – Statistics → Conversations, scheda TCP]

5.3 Assenza di attività successive alla scansione

Nella finestra temporale coperta dalla cattura non sono stati rilevati tentativi di autenticazione, trasferimenti di credenziali in chiaro, richieste HTTP applicative o altro traffico riconducibile a uno sfruttamento attivo delle porte aperte. L'attività osservata si esaurisce nella fase di ricognizione.

6. IPOTESI SUL VETTORE DI ATTACCO

Sulla base degli IOC identificati, l'attività registrata corrisponde alla fase di Reconnaissance del ciclo di attacco (Cyber Kill Chain), classificabile secondo il framework MITRE ATT&CK come Network Service Scanning (tecnica T1046, tattica Discovery). L'host 192.168.200.100 ha svolto un'enumerazione attiva dei servizi di rete esposti da 192.168.200.150, verosimilmente tramite lo strumento Nmap in modalità TCP Connect scan, con l'obiettivo di mappare la superficie d'attacco del target in vista di una successiva fase di exploitation.

È importante rimarcare, per accuratezza, che questa cattura non documenta di per sé una compromissione avvenuta, bensì la fase preparatoria che tipicamente la precede: le 12 porte aperte individuate — in particolare FTP (21), SMB (445) e NetBIOS (139), storicamente tra i servizi più vulnerabili sulla piattaforma Metasploitable2 — rappresentano i punti d'ingresso che un attaccante utilizzerebbe nella fase successiva.

7. RACCOMANDAZIONI E MITIGAZIONI

7.1 Azioni immediate/reattive

- Isolamento di rete: segregare temporaneamente l'host 192.168.200.150 (ad es. su VLAN dedicata o tramite regole firewall) per impedire l'avanzamento dell'attaccante verso la fase di exploitation.
- Blocco dell'IP sorgente: bloccare 192.168.200.100 a livello di firewall/IPS, tenendo presente che tale misura è un primo contenimento e non risolutiva in caso di IP spoofing o uso di proxy da parte dell'attaccante.

- Verifica di compromissione: controllare i log dei servizi esposti sulle porte identificate come aperte (in particolare 21, 139, 445) per escludere tentativi di accesso successivi allo scan.
- Disattivazione temporanea dei servizi non essenziali: rexec, rlogin e rsh (porte 512–514) sono protocolli legacy che trasmettono in chiaro e vanno disabilitati salvo necessità operativa comprovata.

7.2 Azioni strutturali/preventive

- Riduzione della superficie d'attacco: eliminare o sostituire i servizi obsoleti e non cifrati (FTP, Telnet, r-services) con equivalenti sicuri (SFTP/SSH).
- Segmentazione di rete: impedire che host con servizi critici (SMB, rpcbind) siano direttamente raggiungibili da reti non fidate, tramite DMZ, VLAN dedicate o architetture zero-trust.
- Firewall con rilevamento anti-scan: configurare regole di rate-limiting che individuino pattern di numerosi SYN verso porte diverse dallo stesso IP in un breve intervallo temporale, bloccandoli o generando alert.
- Sistemi IDS/IPS con signature dedicate: strumenti come Snort o Suricata dispongono di regole native per il rilevamento di scansioni Nmap, basate sul medesimo pattern identificato in questa analisi, consentendo un rilevamento in tempo reale anziché solo forense.
- Patch management e vulnerability assessment periodico: condurre scansioni di vulnerabilità interne regolari per ridurre la superficie effettivamente sfruttabile, anche qualora venga scoperta da un attaccante esterno.
- Logging centralizzato: l'adozione di un SIEM con una baseline del traffico normale consente di distinguere una scansione legittima e autorizzata (es. vulnerability assessment interno) da una malevola, e di correlare l'evento con eventuali fasi successive dell'attacco

8. CONCLUSIONI

L'analisi della cattura ha permesso di identificare in modo univoco un evento di network scanning condotto tramite tecnica TCP Connect, verosimilmente con Nmap, contro un host che espone il fingerprint di servizi tipico di Metasploitable2. Sebbene non sia stata riscontrata evidenza di sfruttamento attivo all'interno della finestra temporale catturata, l'evento costituisce un indicatore di compromissione di elevata rilevanza in quanto tipicamente precede un tentativo di intrusione. Le raccomandazioni fornite mirano sia al contenimento immediato sia alla riduzione strutturale della probabilità di successo di attacchi futuri della stessa natura.

